

SIMATS ENGINEERING
ASSESSMENT TOOL I – SCENARIO-BASED ASSESSMENT (HIGH)

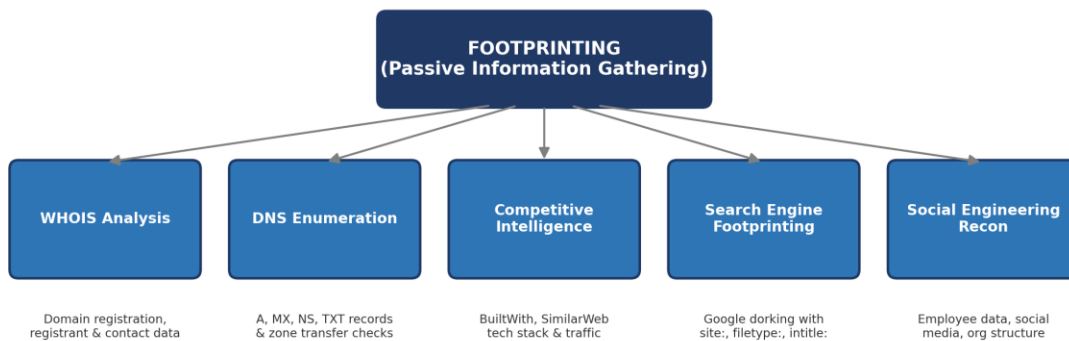
Course Name: Ethical Hacking for Secure Networks
Code: ITA1436 | CO: CO2 | Duration: 90 min
Total Marks: 50 | Assessment Weightage: 35%

AJAY U
192421237

*CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.
(BL3)*

Footprinting is the first and most critical phase of ethical hacking, in which an attacker or security analyst passively collects publicly available information about a target organization before any active engagement with its systems. The scenarios below cover WHOIS analysis, competitive intelligence, DNS enumeration, search engine footprinting, and DNS zone transfer vulnerabilities — the five pillars of reconnaissance assessed in this exercise.

Footprinting & Reconnaissance Overview



Goal: Build a comprehensive profile of the target organization without directly interacting with (or alerting) its systems.

Scenario 1: WHOIS & Recon-ng Based Reconnaissance

A cybersecurity analyst collects publicly available domain, IP, and contact information for a multinational company using WHOIS, Recon-ng, and search engines before any active scanning.

Q1. Explain how WHOIS can be used during footprinting.

WHOIS is a query-and-response protocol used to look up ownership and registration details of a domain name or IP address block from public registrar/registry databases. During footprinting, an analyst runs a WHOIS lookup on the target's domain to extract:

- **Registrant details:** organization name, administrative and technical contact names, email addresses, and phone numbers
- **Domain metadata:** creation date, last-updated date, and expiration date of the domain
- **Name server information:** the authoritative DNS servers handling the domain, which hints at the hosting/DNS provider
- **Registrar information:** the company through which the domain was registered, useful for social engineering pretexts

This information helps build an organizational profile, identify key personnel who could be targeted for social engineering, and reveal infrastructure providers — all without sending a single packet to the target's live systems.

Q2. What information can Recon-ng gather about a target organization?

Recon-ng is a modular, web-reconnaissance framework written in Python with a Metasploit-like interface. Using its built-in and API-integrated modules, it can automatically gather:

- **Subdomains and hostnames:** via search-engine scraping and certificate transparency modules
- **IP addresses and netblocks:** resolved from discovered hostnames
- **Employee names and email addresses:** harvested from search engines, LinkedIn, and public breach data sources
- **Geolocation data:** mapped from discovered IP addresses
- **Social media and metadata:** document metadata (authors, software used) extracted from publicly hosted files

Because Recon-ng stores all findings in a structured workspace database, the analyst can pivot between data types (e.g., domain → subdomain → IP → geolocation) to build a complete attack-surface map.

Q3. Why is passive information gathering preferred before active scanning?

- **Stealth and low detection risk:** passive methods only query third-party public sources (registrars, search engines, caches), so no traffic touches the target's network and no alerts are triggered on IDS/IPS or firewalls
- **Legal and ethical safety:** publicly available data can be collected without prior authorization, whereas active scanning against systems the analyst does not own requires explicit permission

- **Better planning for active phases:** passive recon reveals the scope, subdomains, technologies, and personnel in advance, allowing active scanning to be targeted, efficient, and less noisy
- **Reduced risk of tipping off the target:** avoiding early detection preserves the element of surprise for a genuine penetration test or red-team engagement

Scenario 2: Competitive Intelligence Gathering

A security consultant analyzes competitor websites using BuiltWith and SimilarWeb to understand technologies, hosting platforms, and traffic patterns for a startup launching a cloud-based service.

Q1. How does BuiltWith help in competitive intelligence?

BuiltWith is a website-profiling tool that scans a site's front-end and back-end footprint and reports the technology stack in use. It helps competitive intelligence by revealing:

- **Content Management Systems and frameworks:** e.g., WordPress, React, or a custom framework
- **Hosting and CDN providers:** such as AWS, Cloudflare, or Azure, indicating infrastructure choices
- **Analytics, advertising, and marketing tools:** used by the competitor, showing business strategy
- **Plugins, widgets, and third-party integrations:** including payment gateways and security tools (e.g., WAFs, SSL certificate providers)

For a security team, this same data doubles as an attack-surface indicator — outdated plugins, unpatched CMS versions, or weak SSL configurations found on competitor sites highlight risks the startup should proactively avoid in its own stack.

Q2. What type of information can SimilarWeb provide?

- **Traffic estimates:** monthly visits, page views, and average visit duration for a competitor's website
- **Traffic sources:** breakdown of direct, organic search, paid search, referral, and social traffic
- **Audience demographics and geography:** countries and regions the visitors come from
- **Engagement and ranking metrics:** bounce rate and global/country/category traffic rank
- **Top referring and competing sites:** other domains that send traffic to or compete with the target site

This paints a picture of the competitor's market reach, marketing channels, and user base — useful for both business strategy and understanding which regions/user segments are most exposed if the competitor were compromised.

Q3. How can competitive intelligence improve cybersecurity planning?

- **Benchmarking security posture:** comparing the organization's technology stack and configurations against industry peers helps identify gaps
- **Identifying shared/industry-wide risks:** if competitors use a common vulnerable plugin or CMS, the organization can avoid or harden the same component

- **Anticipating attacker reconnaissance:** understanding what an attacker could learn about the industry helps the organization pre-emptively reduce its own public footprint
- **Informed technology decisions:** choosing hosting, CDN, and security vendors based on what has proven resilient or vulnerable among competitors

Scenario 3: DNS Enumeration for a Financial Organization

An ethical hacker performs DNS enumeration on a financial organization's public infrastructure and discovers undocumented subdomains and mail server configurations.

Q1. What is DNS enumeration?

DNS enumeration is the process of systematically querying an organization's Domain Name System to identify all associated DNS records, hostnames, subdomains, and mail servers. It is performed using tools such as nslookup, dig, dnsrecon, dnsenum, and Fierce, and may include brute-forcing common subdomain names, querying public DNS resolvers, and checking certificate transparency logs. The goal is to build a complete map of the organization's externally visible infrastructure, which forms the foundation for identifying live hosts to target in later reconnaissance or scanning phases.

Q2. Which DNS records are commonly collected during reconnaissance?

- **A / AAAA records:** map hostnames to IPv4/IPv6 addresses of live servers
- **MX records:** identify mail servers, useful for phishing and email-based attack planning
- **NS records:** list the authoritative name servers managing the domain
- **CNAME records:** reveal aliases pointing to other hostnames, often exposing third-party services (e.g., cloud platforms)
- **TXT records:** may leak SPF/DKIM configurations, domain verification tokens, or internal notes
- **SOA record:** provides the primary name server, administrator contact, and zone serial/refresh timers
- **PTR records:** used for reverse lookups, mapping IP addresses back to hostnames

Q3. How can exposed DNS information create security risks?

- **Expanded attack surface:** undocumented subdomains discovered via DNS enumeration may host outdated or forgotten applications with unpatched vulnerabilities
- **Mail server targeting:** exposed MX records let attackers craft phishing campaigns or attempt direct attacks against mail infrastructure
- **Infrastructure fingerprinting:** hostnames and CNAME chains can reveal third-party vendors, cloud providers, or internal naming conventions that assist further attacks
- **Loss of confidentiality:** internal-only systems that were never meant to be public (e.g., "dev", "staging", "vpn" subdomains) become discoverable targets

Scenario 4: Search Engine Footprinting

Using advanced search engine operators, an ethical hacker discovers publicly accessible employee directories and configuration documents revealing internal system details.

Q1. What is search engine footprinting?

Search engine footprinting (also called Google dorking or Google hacking) is a passive reconnaissance technique that uses standard search engines and their advanced query operators to locate sensitive or unintentionally exposed information about a target organization. Because search engines continuously crawl and index publicly accessible web content — including files that were never meant to be discovered — an attacker can retrieve directories, documents, login portals, and configuration files simply by crafting precise search queries, without ever directly contacting the target's servers.

Q2. How do search operators help locate sensitive information?

- **site::** restricts results to a specific domain, e.g., `site:example.com` to enumerate all indexed pages of the target
- **filetype:** / **ext::** filters results to specific file types such as `filetype:pdf` or `filetype:xls`, useful for finding exposed reports, spreadsheets, or configuration files
- **intitle:** / **inurl::** finds pages with specific words in the title or URL, e.g., `intitle:"index of"` to locate open directory listings
- **intext::** searches for specific keywords within the page body, such as `intext:"password"` or `intext:"confidential"`
- **cache::** retrieves a search engine's cached version of a page, sometimes exposing content already removed from the live site

Combining these operators (e.g., `site:example.com filetype:xlsx intext:"employee"`) lets an attacker precisely target exposed employee directories, credentials, or internal documents that were inadvertently indexed.

Q3. What steps should organizations take to protect confidential files?

- **Restrict indexing:** use `robots.txt`, meta `noindex` tags, and `X-Robots-Tag` headers to prevent search engines from crawling sensitive directories
- **Access controls:** place authentication and authorization in front of any internal document repositories rather than relying on "security through obscurity"
- **Regular exposure audits:** periodically run Google dork queries against the organization's own domain to proactively discover what is publicly indexed
- **Secure file storage practices:** avoid uploading sensitive files (HR records, configs, credentials) to publicly accessible web directories in the first place
- **Employee awareness training:** educate staff on the risks of uploading internal documents to public-facing systems or misconfiguring cloud storage buckets

A financial organization's DNS server is found to allow unrestricted zone transfers, exposing a complete list of internal and external hosts to potential attackers.

Q1. What is a DNS zone transfer?

A DNS zone transfer (technically the AXFR, or Asynchronous Full Zone Transfer, mechanism, with IXFR for incremental updates) is the process by which a secondary/slave DNS server replicates the complete zone database from a primary/master DNS server, keeping DNS records synchronized. Legitimately, this is how organizations maintain redundant, consistent DNS infrastructure across multiple servers. However, if a DNS server is misconfigured to accept zone-transfer requests from any client rather than only from its authorized secondary servers, anyone on the internet can request and instantly receive the organization's entire DNS zone file in one query — using simple tools like `dig axfr` or `nslookup`.

Q2. Why is unrestricted zone transfer considered a security risk?

- **Complete infrastructure disclosure:** a single request returns every host, subdomain, and IP address in the zone — information that would otherwise require extensive brute-forcing to discover
- **Reveals internal architecture:** internal hostnames (e.g., `db-internal`, `backup-server`, `vpn-gateway`) that were never meant to be public are exposed, giving attackers a ready-made target list
- **Accelerates the attack lifecycle:** reconnaissance that would normally take days of enumeration is reduced to seconds, letting attackers move faster to scanning and exploitation
- **Facilitates targeted attacks:** knowledge of mail servers, admin panels, and backup systems allows precise phishing, spoofing, or direct exploitation attempts against high-value hosts

Q3. How can organizations prevent unauthorized zone transfers?

- **Restrict AXFR by IP:** configure the DNS server to allow zone transfers only to the specific IP addresses of authorized secondary name servers
 - **Use TSIG authentication:** implement Transaction Signature (TSIG) keys so that zone-transfer requests must be cryptographically authenticated between primary and secondary servers
 - **Disable zone transfers where unnecessary:** if no secondary server needs a full transfer, disable AXFR entirely on public-facing DNS servers
 - **Apply split-horizon / split-view DNS:** serve a restricted, public-only DNS view to the internet while keeping internal records on a separate, non-public DNS view
 - **Monitor and audit DNS configuration:** regularly test the organization's own DNS servers (e.g., with `dig axfr`) and review firewall rules to confirm zone transfers remain locked down
-